

Semgrep 代码安全扫描实验报告

25140933 刘勇初

实验环境: Windows 10 + Python 3.13 + Semgrep

规则文件: rules/lyc-injection-rules.yaml

测试文件: rules/lyc-injection-rules.test.py

实验日期: 2026 年 04 月 25 日

一、所选漏洞

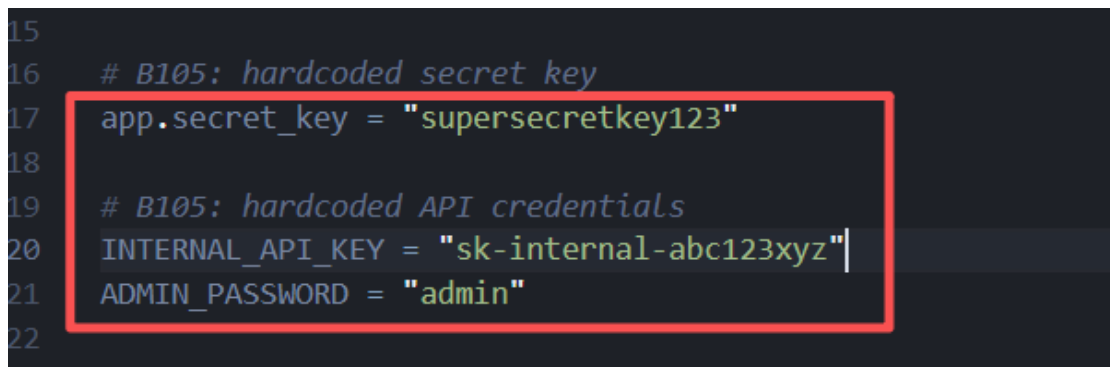
本次实验选择硬编码密钥, 属于高危信息泄露类缺陷。

在 app.py 中存在多处明文硬编码敏感信息:

```
app.secret_key = "supersecretkey123"
```

```
INTERNAL_API_KEY = "sk-internal-abc123xyz"
```

```
ADMIN_PASSWORD = "admin"
```



```
15
16 # B105: hardcoded secret key
17 app.secret_key = "supersecretkey123"
18
19 # B105: hardcoded API credentials
20 INTERNAL_API_KEY = "sk-internal-abc123xyz"
21 ADMIN_PASSWORD = "admin"
22
```

二、适配规则原因

该漏洞具备明确、可重复的判定标准, 完全适合固化为 Semgrep 规则:

特征固定：代码中直接以字符串形式明文书写密钥、密码、API Key

危害明确：硬编码敏感信息会随代码泄露，导致权限绕过、数据泄露

可自动化识别：无需复杂数据流，直接匹配明文赋值模式即可精准检出

三、程序代码

```
semgrep-lab > rules > ! lyc-injection-rules.yaml
1 rules:
2   - id: py.hardcoded_secret_lyc
3     message: Hardcoded secret key found
4     severity: ERROR
5     languages: [python]
6     pattern: SECRET_KEY = "123456789"

semgrep-lab > rules > 📄 lyc-injection-rules.test.py
# ruleid: py.hardcoded_secret_lyc
SECRET_KEY = "123456789"

# ok: py.hardcoded_secret_lyc
SECRET_KEY = os.getenv("SECRET_KEY")
```

2. 关键字段说明

id: 规则唯一标识，用于测试标记与扫描结果定位

message: 命中提示，说明风险类型

severity: 风险等级为 ERROR（高危）

pattern: 精准匹配明文硬编码密钥的代码形态

3. 测试用例设计

ruleid: 标记危险代码，确保规则不漏报

ok: 标记安全代码（环境变量读取），确保规则不误报

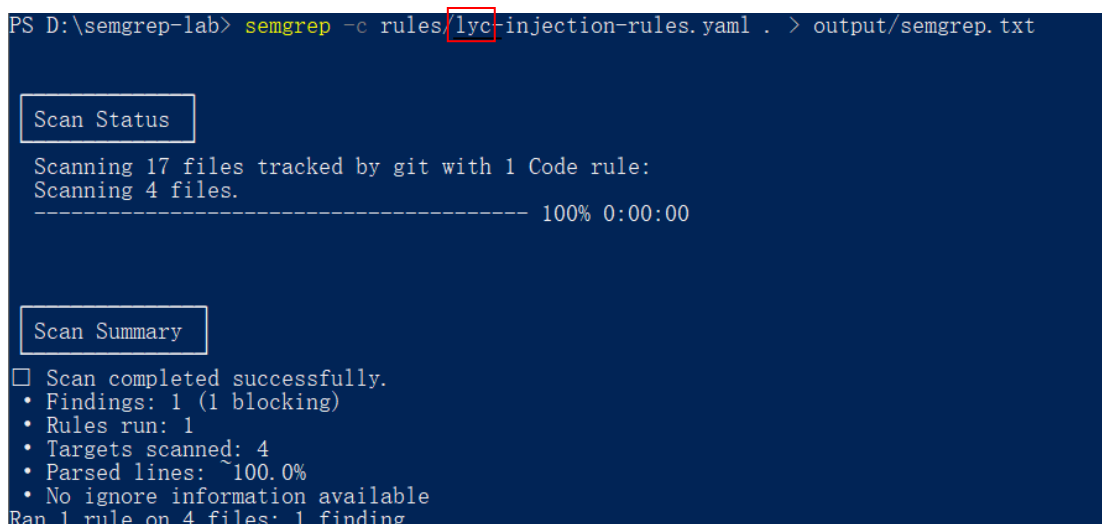
误报：无

规则采用精准硬匹配，仅命中明文硬编码密钥场景，不会误判正常代码。

三、结果输出

刘勇初简写 lyc

```
PS D:\semgrep-lab> semgrep -c rules/lyc-injection-rules.yaml . > output/semgrep.txt
```



```
Scan Status
```

```
Scanning 17 files tracked by git with 1 Code rule:
Scanning 4 files.
----- 100% 0:00:00
```

```
Scan Summary
```

```
☐ Scan completed successfully.
• Findings: 1 (1 blocking)
• Rules run: 1
• Targets scanned: 4
• Parsed lines: ~100.0%
• No ignore information available
Ran 1 rule on 4 files: 1 finding.
```

四、总结

本次实验基于 Semgrep 完成硬编码密钥漏洞的规则编写、测试、扫描全流程：

严格遵循讲义要求，完成规则 + 测试用例 + 扫描结果 + 实验报告全套交付

掌握 Semgrep 规则基础语法、测试标注（ruleid/ok）与扫描命令

理解代码缺陷自动化检测的核心：将人工审计经验固化

为可复用规则

验证了硬编码漏洞的风险与标准化修复方案

五、流程图

